DomiAffaire: ISO/IEC 5055 review B

Knowledge + the ISO/IEC 5055:2021 text · Claude Code · 2026-10-15 · Step 3 of the audit

> **Method.** (1) Read the standard's 248 pages: tables 6.4–6.7, clauses 7–9. (2) Checked only the publisher's sources, CISQ and OMG (ASCQM 1.0). (3) Gave every finding of review A a verdict, re-searched the code for each ISO weakness, and applied the standard's default thresholds.

1. How good was the knowledge-only review (A)?

Verdict on the 61 findings of A	Count
✅ ISO 5055 weakness with the correct CWE	**12**
⚠️ Real issue, but counted under another CWE, or the ISO pattern does not apply here	**16**
❌ Real issue but **not** an ISO 5055 weakness	**33**

> **Key lesson.** Of the 5 *Critical* findings of A, only 2 (S04, S14) are counted by ISO 5055. The ISO security list has **no authorization weaknesses** (no CWE-639/862/284, no CWE-200). So "any client can delete any account" is invisible to the measure. The standard says so itself: its measures are "correlated measures rather than absolute measures" (1.2).

Characteristic (A's label)	✅	⚠️	❌
Security	2	3	16
Reliability	5	6	7
Performance Efficiency	1	3	4
Maintainability	4	4	6

- **Thresholds decide.** "Complex methods" is not a weakness here: maximum cyclomatic complexity is 11, below the ISO limit of 20. "Too many parameters" is not either: 7 is not more than 7.
- **Wrong CWE numbers.** Recalled CWEs 639, 862, 200, 307, 942, 489, 1104 and 1106 do not exist in ISO 5055. Optional.get() without a check is CWE-252 in ISO terms.
- **Missed weaknesses.** Reading the standard found **15 weaknesses that review A missed** (14 counted today + 1 potential), mostly counting rules: data accesses per method, fan-out, string concatenation, switch without default, security exceptions not logged, unchecked loop input.

2. The ISO/IEC 5055 measure for DomiAffaire (expert estimate)

Characteristic	Occurrences	per KLOC		Main weaknesses (occurrences)
Maintainability	**182**	12.6		CWE-1041 Redundant code (copy-paste) (77), CWE-1048 Excessive fan-out (68), CWE-561 Dead code (14), CWE-783 Operator precedence logic error (6)
Performance Efficiency	**86**	5.9		CWE-1046 String concatenation (42), CWE-1073 Method > 2 data accesses (29), CWE-1050 Resource use inside loops (8), CWE-1043 Data element > 5 non-primitive members (3)
Reliability	**48**	3.3		CWE-476 NULL dereference (17), CWE-252 Unchecked return value (13), CWE-248 Uncaught exception (8), CWE-1051 Hard-coded network resource data (5)
Security	**31**	2.1		CWE-252 Unchecked return value (13), CWE-783 Operator precedence logic error (6), CWE-571 Expression always true (3), CWE-1057 Data access outside data manager (2)

Rule (clause 9): occurrences per weakness, summed per characteristic. A weakness listed in several characteristics (e.g. CWE-772, CWE-424) counts in each. Density uses 14.5 KLOC (5,747 Java + 8,710 TypeScript). **Not ISO-conformant:** clause 2 requires automated, objective counting; these are manual and heuristic counts. CAST and SonarQube come next.

3. Verdicts on the most important findings of A

ID	Finding (A)	Verdict	ISO reference
S04	Hard-coded JWT signing key	✅ in ISO 5055	CWE-321 (child of CWE-798), 7.4.17 / 7.4.56, pattern 8.44 The literal key is passed to the signing primitive: exactly 'Ban Hard-Coded Literals used to Connect to Resource' ('covers ... encryption keys, tokens').
S07	Any client or accountant can delete any account	❌ not in ISO 5055	- CWE-639/862 (missing authorization) are not in ISO 5055.
S08	Profile update by path id: overwrite other users and their role	❌ not in ISO 5055	- CWE-639 is not in ISO 5055.
S14	Chat service has no authentication; sender id is trusted from the client	⚠️ partly / other CWE	CWE-424 + CWE-1057, 7.4.23 / 7.4.71, pattern 8.45 'Ban Unintended Paths' Re-classified. CISQ describes this pattern as 'a path from the user interface directly to the database without passing through user authentication routines': the chat service is exactly that. Counted once in Performance, Reliability (424) and Security.
S01	Public endpoint returns every user with password hash	❌ not in ISO 5055	- CWE-200 and CWE-862 are not in any ISO 5055 list (Tables 1-4). Real, critical issue, but outside the measure.
S19	Angular sanitizer bypassed on consultation details	✅ in ISO 5055	CWE-79, 7.4.55, pattern 8.91 Stored user input reaches the page after the vetted sanitizer is bypassed (bypassSecurityTrustHtml).
R01	Optional.get() without check: unknown ids crash with HTTP 500	⚠️ partly / other CWE	CWE-252 Unchecked Return Value, 7.3.13 / 7.4.15 Re-classified: the Optional returned by findById is used without checking it. Counted in Reliability and Security (13 occurrences).
R02	String fields compared without null check	✅ in ISO 5055	CWE-476, 7.3.27, pattern 8.11 Dereference without a NULL check (15 occurrences).
R03	Operator-precedence bug in every file-type check	✅ in ISO 5055	CWE-783, 7.1.8 / 7.4.50 Operator-precedence logic error (6 occurrences); ISO counts it in Maintainability and Security.
R09	Exceptions swallowed with printStackTrace	✅ in ISO 5055	CWE-390, 7.3.16, pattern 8.23 Catch block that neither re-throws nor returns the error (2 occurrences).
R15	Front end never releases subscriptions or the WebSocket	✅ in ISO 5055	CWE-772, 7.2.4 / 7.3.44 / 7.4.46 The STOMP connection is never released (1 occurrence, counted in Performance, Reliability and Security).
P01	Scheduler reloads all deadlines every second	⚠️ partly / other CWE	CWE-1050, 7.2.18, pattern 8.107 Running every second is not itself an ISO weakness; the database writes inside its loop are (counted in P04).
P02	File contents stored inside documents and sent in every list	❌ not in ISO 5055	- CWE-1049 needs SQL joins/sub-queries on 1,000,000-row tables; not applicable. Related CWE-1043 is counted in N04.
M01	God class: DomiAffaireServiceImpl	✅ in ISO 5055	CWE-1080 (7.1.26) + CWE-1048 (7.1.22) 1,585 lines > 1,000; most of its methods exceed 5 outward calls (N03).
M02	Heavy code duplication	✅ in ISO 5055	CWE-1041, 7.1.18, pattern 8.117 47 Java method pairs are more than 90 % similar (63 of 258 methods), plus 31 copies of the same error handler in Angular.
M10	Long, deeply nested methods	❌ not in ISO 5055	CWE-1121 threshold not reached Highest cyclomatic complexity found is 11 (checkDeadlines); the ISO threshold is 20.
M11	Too many parameters	❌ not in ISO 5055	CWE-1064 threshold not reached 7 parameters; the ISO threshold is 'more than 7'.

4. New weaknesses found only with the standard (review B)

ID	Characteristic	Weakness	ISO CWE / pattern	Occ.
N01	Performance Efficiency	Methods with more than 2 data accesses	CWE-1073, 7.2.6, pattern 8.110 (threshold 2)	29

N02	Maintainability	Method with more than 7 data accesses	CWE-1084, 7.1.13, pattern 8.119 (threshold 7)	1
N03	Maintainability	Methods with more than 5 outward calls (fan-out)	CWE-1048, 7.1.22, pattern 8.128 (threshold 5)	68
N04	Performance Efficiency	Data elements aggregating more than 5 non-primitive elements	CWE-1043, 7.2.8, pattern 8.108 (threshold 5)	3
N05	Performance Efficiency	Text built by incremental concatenation	CWE-1046, 7.2.12, pattern 8.111	42
N06	Maintainability	Switch statements without default case	CWE-478, 7.1.2, pattern 8.136	2
N07	Maintainability	Method with excessive commented-out code	CWE-1085, 7.1.24, pattern 8.115	1
N08	Maintainability; Reliability	Hard-coded network resource identifiers	CWE-1051, 7.1.14 / 7.3.65, pattern 8.44	5
N09	Maintainability	Hard-coded literals used to initialise data	CWE-1052, 7.1.21, pattern 8.130	3
N10	Maintainability	Layer-skipping call: controller uses repository	CWE-1054, 7.1.11, pattern 8.45	1
N11	Reliability	Declared exceptions not caught by the caller	CWE-248, 7.3.12, pattern 8.66	8
N14	Security	User input controls a loop bound	CWE-606, 7.4.35, pattern 8.98	1
N15	Security	Caught security exception not logged	CWE-778, 7.4.48, pattern 8.100	1
N16	Security	Use of an obsolete function	CWE-477, 7.4.27, pattern 8.94	1
N17	Performance Efficiency	Query on a field without index (potential)	CWE-1067, 7.2.15, pattern 8.104	0

5. Conclusions

1. **ISO 5055 measures structural quality, not everything.** This app's worst risks (authorization) are outside its list.
2. **The standard brings precision.** Exact CWE IDs, thresholds and a counting rule replace impressions.
3. **Manual counting is not conformant.** It is slow and approximate. Specialized tools are needed: next, CAST and SonarQube.

Sources. ISO/IEC 5055:2021(E), first edition 2021-03. CISQ, it-cisq.org/standards/code-quality-standards. OMG ASCQM 1.0, formal/20-01-02, omg.org/spec/ASCQM/1.0. Full report: reports/03-review-iso.md · data: findings.csv